Security, data protection and content quality

How the RALK Training Platform (app.ralk.io) is hosted, protected and maintained. This factsheet lists technical and organisational measures as implemented at the date of issue.

HOSTING AND ARCHITECTURE

- **Frontend** (ralk.io, app.ralk.io): Vercel
- **Backend API:** Railway, deployment region europe-west4 (EU)
- **Database:** MongoDB Atlas (user accounts, training records, certificates)
- All services are delivered over HTTPS (TLS)
- Backend accepts browser requests only from configured RALK origins (CORS allow-list)

SECURITY HEADERS (APP.RALK.IO)

- Strict-Transport-Security (HSTS, 1 year, including subdomains)
- Content-Security-Policy, framing blocked (frame-ancestors 'none')
- X-Frame-Options: DENY · X-Content-Type-Options: nosniff
- Referrer-Policy and Permissions-Policy (camera, microphone, geolocation disabled)

AUTHENTICATION AND SESSIONS

- Sign-in with Google or Microsoft work account (OAuth 2.0 with PKCE)
- Employees: one-time e-mail login links, single use, valid for 20 minutes, stored only as hashes
- Administrators: second factor by one-time code sent by e-mail on every sign-in (valid 10 minutes, limited attempts)
- Passwords, where used, are stored only as Argon2 hashes
- Session tokens in httpOnly cookies, with expiry
- Rate limiting on sign-in and other sensitive endpoints

ACCESS CONTROL AND AUDIT TRAIL

- Role-based access: employee, customer administrator, RALK platform administrator (super-admin)
- Customer data is held per organisation; customer administrator sessions are bound to their own organisation
- Audit log of security-relevant events (e.g. sign-ins, failed codes, certificate issuance) with timestamp, actor and SHA-256 integrity hash
- Certificates carry a unique ID and integrity hash and can be verified online

DATA PROTECTION (GDPR)

- RALK is established in Germany; the EU General Data Protection Regulation applies
- RALK processes users' personal data as a processor on behalf of the customer under a data processing agreement (licence terms, section 8)
- Data subject rights: access, rectification, erasure, restriction, portability, objection (Art. 15–21 GDPR)
- After contract end: export of training records for 30 days, then deletion unless statutory retention applies (licence terms, 7.3)
- Supervisory authority: Landesbeauftragter für den Datenschutz und die Informationsfreiheit Baden-Württemberg
- Privacy policy: check.ralk.io/privacy

SUBPROCESSORS

Vendor	Purpose
Vercel Inc. (USA)	Frontend hosting
Railway (USA)	Backend API hosting
MongoDB Atlas / MongoDB Inc. (USA)	Database: accounts, training records, certificates
Anthropic PBC (USA)	AI model API for personalised training content
OpenAI / DALL·E (USA)	Images for training scenarios
Cloudflare R2 (Cloudflare Inc., USA)	Storage of training images
Resend (USA)	Transactional e-mail (login links, notifications)
FormSubmit.co	Relay for Quick-Check lead form
Google Ireland Ltd. (Google LLC, USA)	Ads conversion measurement on ralk.io, consent-based

Transfers under standard contractual clauses or adequacy decisions where applicable (privacy policy, section 6).

CONTENT QUALITY

Training content is developed under the responsibility of RALK's financial-crime compliance experts on the basis of FATF standards and applicable regulation. RALK uses artificial intelligence as a tool to prepare content and to adapt it to each learner's role, sector and country. The underlying modules, scenarios and assessment logic are reviewed by RALK's experts and are kept under regular review. The content is training material and does not constitute legal advice.

Licence terms, clause 3.2.

PLANNED Independent penetration test